

Seguretat Activa

4

Protecció contra programari maliciós

El primer que heu de fer per protegir el sistema és instal·lar-hi correctament el sistema operatiu amb les aplicacions i les actualitzacions corresponents, sobretot les de seguretat.

També caldrà que tingueu una bona política de còpies de seguretat, tant pel que fa a les dades guardades com pel que fa a la configuració del sistema. D'aquesta manera, en cas que hi hagi una incidència de seguretat, la recuperació del sistema serà al més ràpida i eficaç possible.

Virus i programes maliciosos

El programari maliciós és tot el programari que s'instal·la en el vostre ordinador, sense el vostre consentiment ni coneixement, amb la finalitat de perjudicar-lo o d'obtenir-ne un benefici. Aquest últim cas és el més habitual, de manera que les accions del programari maliciós cada vegada són més sofisticades i difícils d'identificar.

El panorama actual del Malware

Ja no parlem només de "virus". Avui dia, el terme Malware (Malicious Software) engloba diverses amenaces que busquen benefici econòmic, robatori de dades o control del sistema.

- **Ransomware**: Segresta les dades (les xifra) i demana un rescat econòmic.
- **Spyware i Adware**: Programes que espién l'activitat de l'usuari o inunden el sistema amb publicitat no desitjada.
- **Phishing**: No és un fitxer, sinó una tècnica d'enginyeria social per robar credencials simulant entitats de confiança.
- **Troians i Cucs**: Els troians s'amaguen dins d'aplicacions aparentment legítimes, mentre que els cucs es propaguen sols per la xarxa sense intervenció humana.

Què és un virus polimòrfic?

Un virus polimòrfic és un tipus de programari maliciós que canvia el seu propi codi (la seva "forma") cada vegada que s'estén, però mantenint la seva funció malvada original. L'objectiu principal d'aquesta mutació és evitar la detecció per part dels antivirus basats en signatures. Com que el fitxer canvia constantment, la seva "empremta digital" (hash) mai és la mateixa, fent que el diccionari de virus de l'antivirus no el reconegui.

Com funciona?

1. **Motor de mutació**: El virus conté un petit algorisme intern que genera noves claus de xifrat o canvia l'ordre de les instruccions de codi cada cop que infecta un fitxer nou.
2. **Capa externa variable**: El virus es xifra a si mateix amb una clau diferent en cada infecció. Tot i que el "cor" del virus és el mateix, l'aparença externa és totalment nova per al sistema.
3. **Execució**: Quan l'usuari executa el fitxer, el virus es desxifra a la memòria RAM per actuar, però en el disc dur segueix semblant un fitxer diferent.

Què és un virus polimòrfic?

Com es detecten avui dia?

Atès que el polimorfisme fa que el mètode d'examinar arxius buscant virus coneguts sigui insuficient, els sistemes de seguretat actuals utilitzen:

- **Anàlisi de comportament (Heurística)**: En lloc de mirar com "és" el virus, l'antivirus mira què "fa". Si un programa comença a fer accions sospitoses (com monitorar ports o capturar dades sense permís), es bloqueja immediatament.

- **Emulació (Sandboxing)**: L'antivirus executa el fitxer en un entorn segur i aïllat per veure si es desxifra i mostra la seva veritable cara maliciosa abans de deixar que s'executi al sistema real.

Estratègies de Defensa

- **Antivirus Moderns (EDR/XDR):**
  - Signatures (Diccionari): Compara fitxers amb una base de dades de virus coneguts.
  - Anàlisi Heurística: Identifica comportaments sospitosos (ex: un programa que de cop vol xifrar tots els teus documents).

- **Tallafoc (Firewall):** Controla el trànsit de xarxa, permetent o prohibint comunicacions segons les regles establertes.

- **Higiene Digital:**
  - Actualitzacions: Mantenir sempre l'última versió del SO i aplicacions per tancar vulnerabilitats.
  - Mínims privilegis: No utilitzar el sistema sempre com a "Administrador", sinó amb permisos limitats.
  - Còpies de seguretat (Backup): L'única solució definitiva contra el ransomware. Han de ser automatitzades i periòdiques.

SIEM

Fins ara, hem vist eines que funcionen per separat:

- L'antivirus mira l'ordinador.
- El Firewall mira la porta de la xarxa.
- L'IDS mira si algú corre pels passadissos.

El SIEM és la pantalla on el vigilant de seguretat ho veu tot alhora. És un programa que recull els "logs" (registres) de totes les altres eines i els analitza en conjunt per trobar atacs que passarien desapercebuts si els miréssim d'un en un.

La Intel·ligència Artificial: Ofensiva vs Defensiva

Avui dia no es pot parlar de malware sense parlar d'IA.

- **Malware Generat per IA**: Els atacants usen IA per escriure codi maliciós que canvia més ràpid que el polimorfisme clàssic (mutacions en segons).
- **Deepfakes i Phishing avançat**: El phishing ja no són correus amb faltes d'ortografia; ara usen clonació de veu i vídeo per enganyar empleats (enginyeria social 2.0).
- **IA Defensiva**: Els antivirus moderns ja no només usen heurística, usen models d'IA que "prediuen" l'atac abans que passi.

Model Zero Trust (Confiança Zero)

Aquest és el paradigma actual de la seguretat activa.

- **Concepte**: "Mai confiïs, verifica sempre". Ja no n'hi ha prou amb estar "dins" de la xarxa corporativa o tenir un firewall. Cada acció, cada usuari i cada dispositiu s'ha d'autenticar constantment. Privilegi mínim: l'usuari només té accés a allò estrictament necessari per a la seva feina

- **Per què és important?** Perquè si un atacant roba una contrasenya (identitat), el model Zero Trust l'aturarà perquè el comportament o el dispositiu no seran els habituals.

L'Evolució del Ransomware (Extorsió Múltiple)

- **Doble/Triple Extorsió**: No només xifren les dades, sinó que amenacen amb publicar-les (robatori de privacitat) i fins i tot contacten amb els clients de l'empresa atacada per pressionar.
- **Ransomware-as-a-Service (RaaS)**: Ara hi ha "kits" de virus que es lloguen. No cal saber programar per ser un ciberdelinqüent.